labs

Phishing Email Analysis & Incident Response

1. nvironment & Prerequisites

- **OS:** Kali Linux Virtual Machine
- **Target File:** `New_Order_PO-WB-UK-0022.eml`

2. Walkthrough & Investigation Steps

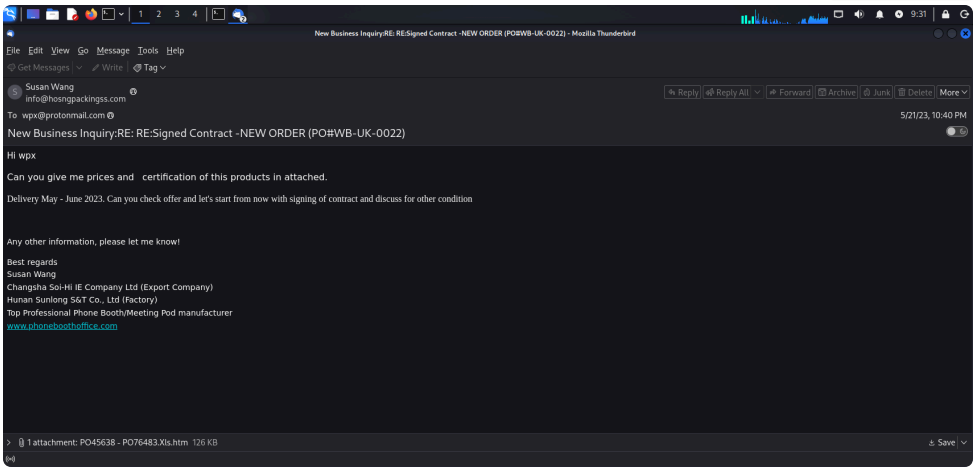
Part 1: First Look & Header Analysis

1. **Open the Email Artifact:**

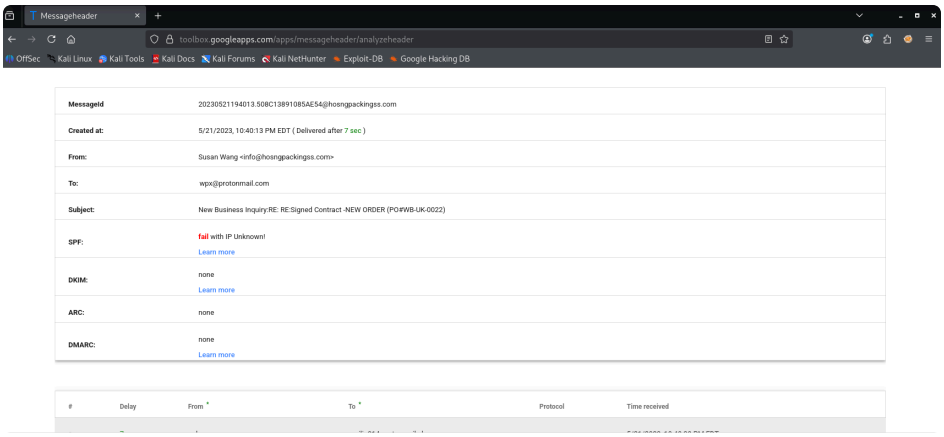
   Bash

   ```
   thunderbird "New_Order_PO-WB-UK-0022.eml"
   ```

   - **Visual Anomalies:** Sender display name does not match email structure (`Susan Wang` `info@hosngpackingss.com`), email uses a false reply prefix (`RE: RE:`), and the attached payload features a suspicious double extension (`.Xls.htm`).

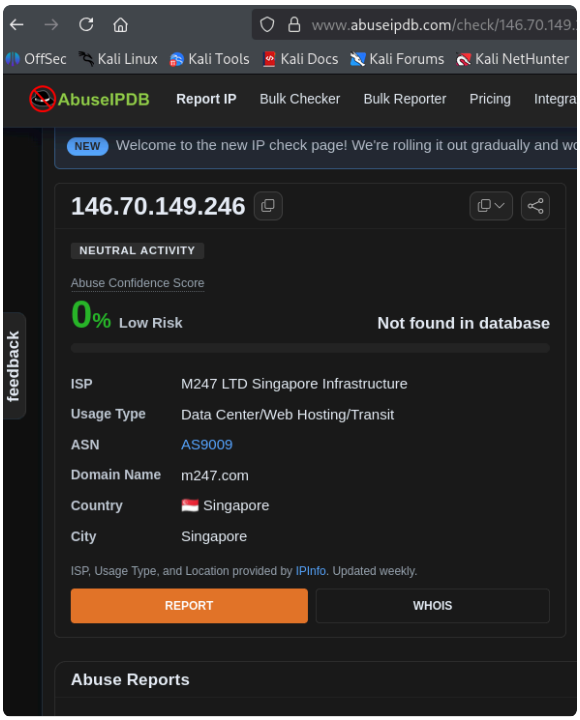
   

2. **Analyze Email Headers:**
   - In Thunderbird, navigate to **View** → **Message Source** to inspect raw headers.
   - Copy the header block (from top down to the first blank line) and submit to Google Admin Toolbox Messageheader.
   - **Result:** SPF validation failed, confirming the sending IP address was unauthorized to send on behalf of the domain.



3. **Originating IP Intelligence:**
    - Locate the originating MTA line in raw headers: Plaintext

      ```
      Received: from mta0.hiranoseiki.co.jp (unknown [146.70.149.246])
      ```
      ```
    - Query the IP `146.70.149.246` on AbuseIPDB.
    - **Result:** IP maps to datacenter infrastructure rather than a legitimate corporate mail server.

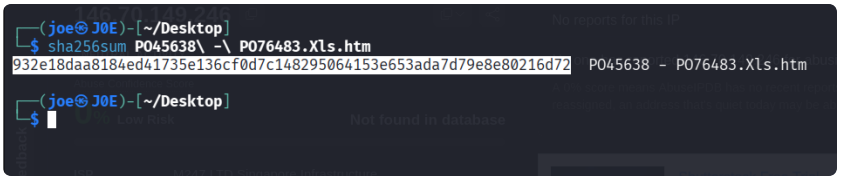



# Part 2: Static Payload & Threat Intelligence Analysis

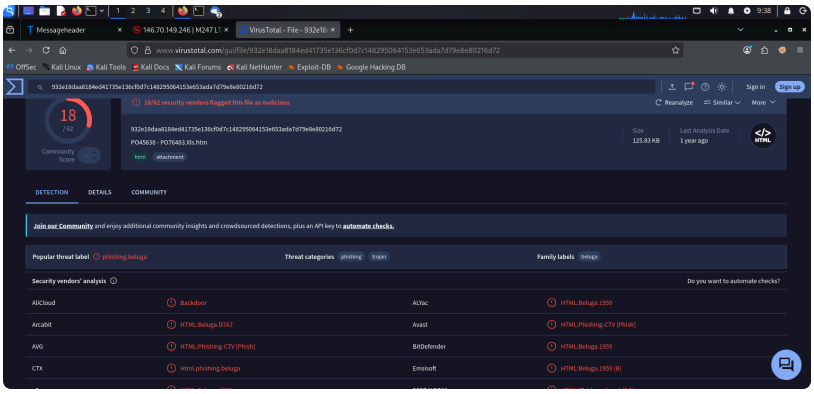
1. **Calculate File Hash:**

   Bash
      ```

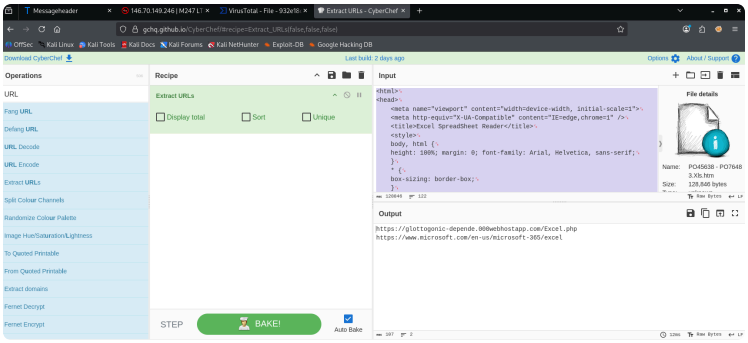
sha256sum "PO45638 - PO76483.Xls.htm"



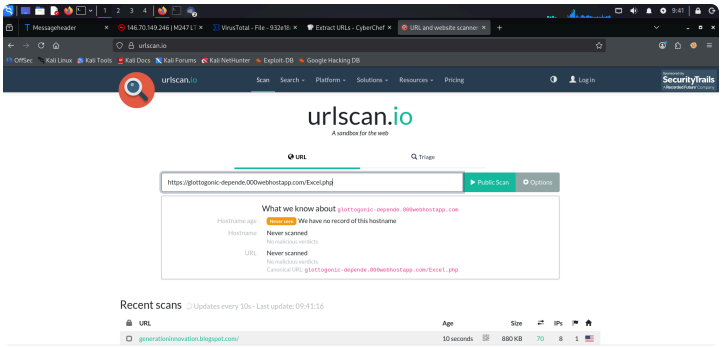
Query the resulting SHA256 hash on VirusTotal to confirm malicious detection flags



2. **Extract Embedded Exfiltration URL:**
   - Load the attachment into CyberChef.
   - Apply the **Extract URLs** operation to retrieve hidden endpoints embedded within the HTML.



3. **URL Analysis:**
   - Submit the extracted domain to urlscan.io.
   - **Result:** Domain inactive/deleted due to the age of the phishing campaign infrastructure.



Part 3: Defanged Indicators of Compromise (IOCs)

IOC Type	Value (Defanged)
Spoofed Sender	`info@hosngpackingss[.]com`
Originating IP	`146[.]70[.]149[.]246`
Credential-Exfil URL	`hxxps://glottogonic-depende[.]000webhostapp[.]com/Excel[.]php`
Attachment SHA256	`932e18daa8184ed41735e136cf0d7c148295064153e653ada7d79e8e80216d72`

3. Task 8 — Verdict and Response

Summary of Evidence

1. **Authentication Mismatch:** The email headers failed SPF/DKIM validation, showing that the sender domain (`hosngpackingss.com`) did not originate from the claimed infrastructure.
2. **Malicious Attachment:** A deceptive double-extension file (`PO45638 - PO76483.Xls.htm`) was extracted and verified via SHA256 hashing, returning high malicious/phishing detections on VirusTotal.
3. **Credential-Exfil URL:** Static analysis of the HTML attachment revealed an embedded exfiltration URL (`hxxps://glottogonic-depende[.]000webhostapp[.]com/Excel[.]php`) designed to harvest user credentials via a fraudulent login form.

Recommended SOC Response Actions

1. **Containment:** Block all associated IOCs (sender domain, originating IP, exfil URL, and file hash) across perimeter defenses, email gateways, and web proxies.
2. **Triage & Remediation:** Query SIEM/endpoint logs to identify any internal users who received, opened, or interacted with the payload, and isolate compromised endpoints for immediate forensic triage.

One-Sentence Executive Summary

Summary: The email was a spoofed business order phishing attempt containing a malicious double-extension HTML attachment designed to harvest user credentials via an embedded exfiltration URL.